

NIST Cybersecurity Framework 2.0 Core



DETECT

- L** Adverse Event Analysis
 - L L** Potentially adverse events are analyzed to better understand associated activities
 - L L** Information is correlated from multiple sources
 - L L** The estimated impact and scope of adverse events are understood
 - L L** Information on adverse events is provided to authorized staff and tools
 - L L** Cyber threat intelligence and other contextual information are integrated into the analysis
 - L L** Incidents are declared when adverse events meet the defined incident criteria
- L** Continuous Monitoring
 - L L** Networks and network services are monitored to find potentially adverse events
 - L L** The physical environment is monitored to find potentially adverse events
 - L L** Personnel activity and technology usage are monitored to find potentially adverse events
 - L L** External service provider activities and services are monitored to find potentially adverse events
 - L L** Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events

GOVERN

- L** Organizational Context
 - L L** The organizational mission is understood and informs cybersecurity risk management
 - L L** Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered
 - L L** Legal, regulatory, and contractual requirements regarding cybersecurity - including privacy and civil liberties obligations - are understood and managed
 - L L** Critical objectives, capabilities, and services that external stakeholders depend on or expect from the organization are understood and communicated
 - L L** Outcomes, capabilities, and services that the organization depends on are understood and communicated
- L** Oversight
 - L L** Cybersecurity risk management strategy outcomes are reviewed to inform and adjust strategy and direction

- L L** The cybersecurity risk management strategy is reviewed and adjusted to ensure coverage of organizational requirements and risks
- L L** Organizational cybersecurity risk management performance is evaluated and reviewed for adjustments needed
- L** Policy
 - L L** Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced
 - L L** Policy for managing cybersecurity risks is reviewed, updated, communicated, and enforced to reflect changes in requirements, threats, technology, and organizational mission
- L** Risk Management Strategy
 - L L** Risk management objectives are established and agreed to by organizational stakeholders
 - L L** Risk appetite and risk tolerance statements are established, communicated, and maintained
 - L L** Cybersecurity risk management activities and outcomes are included in enterprise risk management processes
 - L L** Strategic direction that describes appropriate risk response options is established and communicated
 - L L** Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties
 - L L** A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated
 - L L** Strategic opportunities (i.e., positive risks) are characterized and are included in organizational cybersecurity risk discussions
- L** Roles, Responsibilities, and Authorities
 - L L** Organizational leadership is responsible and accountable for cybersecurity risk and fosters a culture that is risk-aware, ethical, and continually improving
 - L L** Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced
 - L L** Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies
 - L L** Cybersecurity is included in human resources practices
- L** Cybersecurity Supply Chain Risk Management
 - L L** A cybersecurity supply chain risk management program, strategy, objectives,

NIST Cybersecurity Framework 2.0 Core



policies, and processes are established and agreed to by organizational stakeholders

L L Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally

L L Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes

L L Suppliers are known and prioritized by criticality

L L Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and other types of agreements with suppliers and other relevant third parties

L L Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships

L L The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship

L L Relevant suppliers and other third parties are included in incident planning, response, and recovery activities

L L Supply chain security practices are integrated into cybersecurity and enterprise risk management programs, and their performance is monitored throughout the technology product and service life cycle

L L Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement

IDENTIFY

L Asset Management

L L Inventories of hardware managed by the organization are maintained

L L Inventories of software, services, and systems managed by the organization are maintained

L L Representations of the organization's authorized network communication and internal and external network data flows are maintained

L L Inventories of services provided by suppliers are maintained

L L Assets are prioritized based on classification, criticality, resources, and impact on the mission

L L Inventories of data and corresponding metadata for designated data types are maintained

L L Systems, hardware, software, services, and data are managed throughout their life cycles

L Improvement

L L Improvements are identified from evaluations

L L Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties

L L Improvements are identified from execution of operational processes, procedures, and activities

L L Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved

L Risk Assessment

L L Vulnerabilities in assets are identified, validated, and recorded

L L Cyber threat intelligence is received from information sharing forums and sources

L L Internal and external threats to the organization are identified and recorded

L L Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded

L L Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization

L L Risk responses are chosen, prioritized, planned, tracked, and communicated

L L Changes and exceptions are managed, assessed for risk impact, recorded, and tracked

L L Processes for receiving, analyzing, and responding to vulnerability disclosures are established

L L The authenticity and integrity of hardware and software are assessed prior to acquisition and use

L L Critical suppliers are assessed prior to acquisition

PROTECT

L Identity Management, Authentication, and Access Control

L L Identities and credentials for authorized users, services, and hardware are managed by the organization

L L Identities are proofed and bound to credentials based on the context of interactions

L L Users, services, and hardware are authenticated

NIST Cybersecurity Framework 2.0 Core



L L Identity assertions are protected, conveyed, and verified
L L Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties
L L Physical access to assets is managed, monitored, and enforced commensurate with risk
L Awareness and Training
L L Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind
L L Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind
L Data Security
L L The confidentiality, integrity, and availability of data-at-rest are protected
L L The confidentiality, integrity, and availability of data-in-transit are protected
L L The confidentiality, integrity, and availability of data-in-use are protected
L L Backups of data are created, protected, maintained, and tested
L Technology Infrastructure Resilience
L L Networks and environments are protected from unauthorized logical access and usage
L L The organization's technology assets are protected from environmental threats
L L Mechanisms are implemented to achieve resilience requirements in normal and adverse situations
L L Adequate resource capacity to ensure availability is maintained
L Platform Security
L L Configuration management practices are established and applied
L L Software is maintained, replaced, and removed commensurate with risk
L L Hardware is maintained, replaced, and removed commensurate with risk
L L Log records are generated and made available for continuous monitoring
L L Installation and execution of unauthorized software are prevented
L L Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle

RECOVER

L Incident Recovery Communication
L L Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders
L L Public updates on incident recovery are shared using approved methods and messaging
L Incident Recovery Plan Execution
L L The recovery portion of the incident response plan is executed once initiated from the incident response process
L L Recovery actions are selected, scoped, prioritized, and performed
L L The integrity of backups and other restoration assets is verified before using them for restoration
L L Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms
L L The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed
L L The end of incident recovery is declared based on criteria, and incident-related documentation is completed

RESPOND

L Incident Analysis
L L Analysis is performed to establish what has taken place during an incident and the root cause of the incident
L L Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved
L L Incident data and metadata are collected, and their integrity and provenance are preserved
L L An incident's magnitude is estimated and validated
L Incident Response Reporting and Communication
L L Internal and external stakeholders are notified of incidents
L L Information is shared with designated internal and external stakeholders
L Incident Management
L L The incident response plan is executed in coordination with relevant third parties once an incident is declared
L L Incident reports are triaged and validated
L L Incidents are categorized and prioritized
L L Incidents are escalated or elevated as needed
L L The criteria for initiating incident recovery are applied
L Incident Mitigation
L L Incidents are contained

NIST Cybersecurity Framework 2.0 Core



L L Incidents are eradicated